Google Drive & Shared Drives Architecture, Permissions & Governance

Implementation Solution Guide

Version 1.0.0 · 2026-07-06

Contents

Executive Summary 4

1. Solution Overview — Google Drive & Shared Drives Architecture, Permissions & Governance 4

The Drive model — five design decisions, one governed estate . . . 5

Reference design (target state) . . . 6

Benefits . . . 6

Limitations & honest constraints . . . 6

Deployment model . . . 7

2. Requirements 7

2.1 Drive & Docs administration privilege . . . 7

2.2 Google Groups as the membership source of truth . . . 8

2.3 Data classification & DLP policy inputs . . . 8

2.4 Enterprise-tier edition for advanced sharing controls (edition-gated) . . . 8

2.5 An agreed Shared Drives taxonomy & naming standard (design input) . . . 9

2.6 API access for the automation (Admin SDK + Drive API) . . . 9

Global Requirements — Google Workspace & Gemini Solutions 10

1. Google Workspace / Cloud Identity tenant . . . 10

2. Source Microsoft 365 / Entra environment (for migration & coexistence) . . . 10

3. DNS control for the routed domains . . . 11

4. Identity & provisioning source of truth . . . 11

5. A pilot scope (OU / group) and change control . . . 11

6. Security, compliance & governance stakeholders . . . 11

3. Implementation Guide 12

3.1 Assess — inventory the current Drive exposure (read-only) . . . 12

3.2 Design — agree the taxonomy, roles, sharing policy, DLP alignment, governance . . . 13

3.3 Configure — apply sharing settings, audiences, trust rules, DLP (pilot OU first) . . . 13

3.4 Pilot — run the design against the pilot scope . . . 14

3.5 Validate & Expand . . . 14

3.6 Rollback (documented, per production sharing change) . . . 15

5. Testing & Validation 15

Test 1 — Sharing exposure reduced to policy (Gate G2 / Validate) . . . 15

Test 2 — External-sharing policy conformance (go/no-go gate) . . . 16

Test 3 — Link-sharing default is restricted . . . 16

Test 4 — Target audience is the default suggestion . . . 16

Test 5 — DLP blocks/warns on sensitive external sharing . . . 16

Test 6 — Membership is group-based, roles are least-privilege . . . 17
Test 7 — No orphaned ownership . . . 17
Test 8 — Governance reporting is in place . . . 17
Test 9 — Rollback restores the baseline . . . 17
6. Troubleshooting 17
API & automation . . . 18
Configuration & sharing . . . 18
Ownership, membership & provisioning . . . 19
Gates & rollback . . . 20
7. Best Practices 20
Architecture & taxonomy . . . 20
Membership & least privilege . . . 20
Sharing & the trust boundary . . . 21
Governance & lifecycle . . . 21
Safety & operations . . . 21
8. Deliverables Summary 22
Documentation . . . 22
Python tools (Google Workspace Admin SDK / Drive API) . . . 22
Appendix A — PowerShell Scripts 24

Executive Summary

Outcome. A governed Google Drive estate where collaboration is easy and data stays where it belongs. Business content lives in **organization-owned Shared Drives** (never stranded on a departing employee), the estate follows a clear **taxonomy and naming standard**, access is granted by **group membership** at least privilege, external and link-sharing is **restrictive by default** and opened only to allow-listed partners through governed audiences, sensitive content is **DLP-protected** on external sharing, and every Shared Drive has a named owner and a periodic review — so Drive scales without becoming a sprawl of over-shared, orphaned files.

The problem it solves. Left ungoverned, Drive drifts into risk: files owned by individuals scatter across My Drive, "Anyone with the link" shares outlive their purpose, content leaks to personal external accounts, and when a file's owner leaves the file is orphaned and access breaks. Ad-hoc per-file sharing is invisible and un-auditable. This solution replaces that with a deliberate, documented architecture and the automation to keep it honest.

Approach. Five design decisions — content placement (Shared Drives vs My Drive), taxonomy & naming, membership & role model, external/link-sharing policy with target audiences and trust rules, and DLP-aligned controls plus lifecycle governance — deployed on the house model **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand**. A pilot proves the design on one domain/OU behind explicit pass/fail gates before any fleet-wide rollout. Five Python tools (Admin SDK / Drive API) baseline the current exposure, provision Shared Drives to the model, gate external-sharing conformance, produce the governance report, and keep the catalog consistent.

Why it is low-risk. Every production sharing change is **pilot-first**, **gated**, and **rollback-ready** — the pre-change Admin-console settings are recorded so any change can be cleanly reverted. The automation is **safe by default**: read-only or dry-run unless explicitly told to `--apply`, membership is group-based (individual users are refused), DLP rules move audit → warn → block only after tuning, and **no credentials or keys live in code**. Google Admin console and Drive API behavior is drawn from current public documentation; edition-gated and evolving surfaces are flagged "verify in your tenant." The result is Drive collaboration that is easy to use and safe by design — delivered as a self-guided, tested package at a fraction of consulting cost.

1. Solution Overview — Google Drive & Shared Drives Architecture, Permissions & Governance

Once an enterprise lands on Google Workspace, **Drive is where most of the collaboration — and most of the risk — lives**. Left ungoverned, Drive becomes a sprawl: files owned by individuals scattered across My Drive, "Anyone with the link" shares that outlive the person who made them, external sharing to personal Gmail accounts, and content that no team can find because there is no taxonomy. When the person who owns a critical file leaves, the file is **orphaned** and access breaks. This solution designs the **steady-state Drive and Shared Drives architecture** so collaboration is easy but data stays where it belongs — deployed **pilot-first**, with pass/fail gates and a documented rollback for the sharing changes that are high-impact.

> ***Scope boundary — architecture, not migration.*** *This solution is the* ***steady-state Drive architecture and governance*** *model. The one-time movement of SharePoint / OneDrive content *into* Drive is a separate migration solution and is out of scope here (it is referenced only where the*

*target Shared Drive layout must be agreed **before** data lands). This document assumes the data is in — or is landing in — Google Drive, and designs how it is structured, shared, and governed from that point on.*

Vendor boundary.** Google **Admin console** (admin.google.com) paths and the **Drive API / Admin SDK** used by the Python tools are authored from Google's current public documentation. Several controls named here are **edition-gated** — **target audiences**, **trust rules**, **DLP for Drive**, and the **security investigation tool** require **Enterprise / Education Plus / Enterprise Plus** tiers — and those gates are flagged where they apply. Where a page or toggle is evolving, it is flagged **"verify in your tenant."** Gemini-in-Drive behavior is flagged **"verify in your tenant."

The Drive model — five design decisions, one governed estate

A governed Drive estate is the product of five deliberate design decisions. The reference model below is what the Implementation Guide stands up.

Decision 1 — My Drive vs Shared Drives (where content lives)

The single most important architectural rule: **team and business content lives in Shared Drives, not in individuals' My Drive.** A Shared Drive is owned by the **organization**, not a person — so membership, not ownership, controls access, and no file is orphaned when an employee leaves. My Drive is reserved for genuinely personal drafts and working files. The design defines a **content-placement policy**: which categories of content belong in a Shared Drive (anything a team relies on) versus My Drive (transient personal work), and how existing individually-owned content is relocated.

Decision 2 — Shared Drives taxonomy & naming (structure)

Shared Drives are **flat containers**, not a deep folder tree — so the taxonomy is expressed in the **set of Shared Drives** and a **consistent naming convention**, not in nesting. The design defines a naming standard `<Domain> – <Team/Function> – <Purpose>` (e.g. `Shared Drive – Finance – AP Records`, `Shared Drive – HR – Employee Files – Restricted`) and a small, governed set of top-level domains (Corporate Functions, Business Units, Projects, Cross-Org Collaboration). The taxonomy is the map that makes content findable and makes membership decisions obvious.

Decision 3 — Membership & role model (who can do what)

Access to a Shared Drive is granted by **membership**, and every member holds one of the Drive **roles**: **Manager**, **Content manager**, **Contributor**, **Commenter**, **Viewer**. The design makes membership **group-based, not user-based** — you add a **Google Group** (e.g. `grp-finance-ap@corp.example`) as the member, then manage people by changing group membership, so access is auditable in one place and driven by the directory source of truth. A **role model** assigns the least-privilege default (most business users are **Contributor** or **Viewer**; **Manager** is reserved for a named owner group per Drive).

Decision 4 — External & link-sharing policy (the trust boundary)

This is where data leaks or stays contained. The design sets, at the Admin-console level and per organizational unit / Shared Drive, **who content can be shared with**: internal-only, allow-listed partner domains (via **target audiences** and **trust rules**), or open external. It curtails **"Anyone with the link"** to default-off or internal-only, sets **link-sharing default access**, requires **outside-domain sharing warnings**, and controls whether Shared Drive membership can include people **outside the organization**. The default posture is **restrictive**, opened deliberately per audience.

Decision 5 — DLP-aligned sharing controls & lifecycle governance (keeping it governed)

Sharing policy defines *who can share*; **DLP** defines *what can be shared* — named data-protection rules block or warn when sensitive content (national IDs, financial data, a custom classifier) is shared externally, so classification drives sharing, not just admin defaults. Finally, **governance/lifecycle** keeps the estate healthy over time: a **named owner (Manager group) per Shared Drive**, periodic **access reviews**, an **orphaned-ownership** sweep (files still owned by departed users), a **stale/empty-Drive** review, and a **provisioning standard** so new Shared Drives are created to the model rather than ad hoc.

Reference design (target state)

Layer	Target state
Content placement	Business content in **Shared Drives**; My Drive = personal/transient only
Taxonomy	Governed top-level domains + `<Domain> – <Team> – <Purpose>` naming; flat Drives
Membership	**Group-based** membership; least-privilege role model; a named Manager group per Drive
External sharing	Restrictive default; **target audiences** + **trust rules** for allow-listed partners; link-sharing curtailed
DLP	Data-protection rules block/warn on sensitive external sharing
Governance	Owner per Drive, access reviews, orphaned-owner + stale-Drive sweeps, provisioning standard

Benefits

- **No orphaned content** — organization-owned Shared Drives survive employee departures.
- **Collaboration stays easy** — clear taxonomy makes content findable; group membership is one place to manage access.
- **Data stays contained** — restrictive external/link-sharing defaults plus DLP keep sensitive content in-bounds.
- **Auditable** — access is expressed as group membership and named Drives, not ad-hoc per-file grants.
- **Scales** — a provisioning standard and periodic reviews keep the estate governed as it grows.

Limitations & honest constraints

- **Edition-gated controls.** Target audiences, trust rules, and DLP for Drive require Enterprise-tier editions; on lower tiers the design falls back to OU-level sharing settings and manual review (flagged in Requirements).
- **Shared Drives are flat.** Deep hierarchy must be expressed as separate Drives + a naming

convention, not nested folders — this is a deliberate constraint, not a workaround.

• **Existing sprawl must be remediated.** This design defines the target and the sweeps to get there; relocating already-scattered My Drive content and fixing existing over-shares is an execution effort, not a single switch.

• **Sharing changes are high-impact.** Tightening external/link-sharing can break active collaborations; every production sharing change is piloted, gated, and rollback-ready.

Deployment model

This solution follows the house model — **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand** — with explicit pass/fail gates and a **documented rollback** for every production sharing change:

1. **Assess** — inventory current sharing exposure, external shares, link-sharing, and orphaned ownership (read-only) with `drive_sharing_exposure_assessment.py`.

1. **Design** — agree the taxonomy, naming, role model, external-sharing policy, target audiences, DLP alignment, and lifecycle governance against the reference design above.

1. **Configure** — apply Admin-console sharing settings, create target audiences/trust rules, align DLP, and provision the pilot Shared Drives to the naming model.

1. **Pilot** — run the design against one pilot domain/OU (e.g. `Pilot OU – Drive – Finance`), with a defined pass/fail gate.

1. **Validate** — confirm sharing is scoped to policy, no orphaned ownership remains, and governance reporting is in place with the validation tools.

1. **Expand** — roll the model out domain by domain, keeping the provisioning standard and periodic reviews as steady-state governance.

2. Requirements

These are the **solution-specific** prerequisites for designing and governing the Drive & Shared Drives architecture. They build on — and do not repeat — the shared **Global Requirements for Google Workspace & Gemini Solutions** (`global-requirements-google.md`), which already cover the Workspace/ Cloud Identity tenant + super-admin (GR-1), the identity/provisioning source of truth (GR-4), the pilot scope + change control (GR-5), and the security/compliance/governance stakeholders (GR-6). Confirm those first; then satisfy the items below.

Each requirement is stated as **Description / Why required / How to verify / How to implement if missing.**

2.1 Drive & Docs administration privilege

• **Description:** A super-admin, or a custom **admin role** with the **Drive and Docs** privilege

(Admin console → **Account** → **Admin roles**), able to configure sharing settings, Shared Drive creation controls, and Shared Drive management.

• **Why required:** All sharing-policy and Shared Drive configuration in this solution is performed with this privilege; the Python tools authenticate as this identity (or a delegated service account) to read/manage Drive settings.

• **How to verify:** In **Admin console** → **Account** → **Admin roles**, confirm your role includes the **Services** → **Drive and Docs** privilege set; or sign in as super-admin.

• **How to implement if missing:** Assign the built-in **Super Admin** role or create a custom admin role granting **Drive and Docs**, and (for automation) a **service account with domain-wide delegation** scoped to the Drive/Admin SDK scopes named in §2.6.

2.2 Google Groups as the membership source of truth

• **Description: Google Groups** (synced from, or reconciled with, the directory source of truth in GR-4) that will be used as **Shared Drive members** and as the unit of access management — one or more groups per team/function (e.g. `grp-finance-ap@corp.example`).

• **Why required:** The design mandates **group-based membership**, not per-user grants, so access is auditable and directory-driven. Without governed groups, membership decays into ad-hoc user adds.

• **How to verify:** Confirm the relevant teams have corresponding Google Groups and that group membership is maintained by the source of truth (GCDS/SCIM or Groups for Business), not edited ad hoc.

• **How to implement if missing:** Define the group naming standard and provision the groups (from the IdP/HR source where possible); agree who owns group membership before granting Drive access.

2.3 Data classification & DLP policy inputs

• **Description:** The organization's **data-classification scheme** (e.g. Public / Internal / Confidential / Restricted) and the **DLP detectors** that map to it (national IDs, financial data, regulated content, custom word-lists/regex), owned by the security/data-governance stakeholders in GR-6.

• **Why required:** DLP-aligned sharing controls (Decision 5) block or warn on sensitive external sharing only if classification and detectors are defined; sharing policy alone cannot see content.

• **How to verify:** Confirm a documented classification scheme and the DLP detectors that implement it exist and are approved by data governance.

• **How to implement if missing:** Work with the GR-6 stakeholders to agree the classification scheme and detector set **before** authoring DLP rules; this solution consumes them, it does not invent them.

2.4 Enterprise-tier edition for advanced sharing controls (edition-gated)

• **Description: Target audiences**, **trust rules**, **DLP for Drive**, and the **security

investigation tool **require** Enterprise Standard/Plus, Education Standard/Plus, or Enterprise Plus** (verify your exact edition mapping in your tenant).

• **Why required:** These are the controls that implement scoped external sharing and content-aware blocking. On lower editions the design falls back to OU-level sharing settings + manual review.

• **How to verify:** In **Admin console** → **Billing** → **Subscriptions**, confirm the edition; check that **Directory** → **Target audiences** and **Data** → **Data protection** (DLP) pages are present.

• **How to implement if missing:** Upgrade the affected OUs/licenses through Google or a reseller, or adopt the documented lower-tier fallback (OU sharing settings + `drive_sharing_exposure_assessment.py` driven manual review).

2.5 An agreed Shared Drives taxonomy & naming standard (design input)

• **Description:** A signed-off **taxonomy** (top-level domains) and **naming convention** `<Domain> – <Team/Function> – <Purpose>` for Shared Drives, plus the **role model** (which group is Manager / Content manager / Contributor / Viewer per Drive).

• **Why required:** Provisioning and governance are only consistent if the naming and role model are agreed up front; the provisioner tool enforces this standard.

• **How to verify:** Confirm the taxonomy/naming/role model document exists and is approved by the Drive service owner and the business stakeholders.

• **How to implement if missing:** Run the Design step (Implementation §3.2) to produce it before provisioning any production Shared Drives.

2.6 API access for the automation (Admin SDK + Drive API)

• **Description:** The **Admin SDK Directory & Reports APIs** and the **Drive API** enabled in a Google Cloud project, and an OAuth client **or** a service account with **domain-wide delegation** scoped to the read-only scopes the tools use (and, only where a tool is run with `--apply`, the corresponding write scopes).

• **Why required:** The five Python tools read sharing/ownership/membership state (and, for the provisioner, optionally create/manage Shared Drives) via these APIs.

• **How to verify:** In the Cloud project, confirm **Admin SDK API** and **Google Drive API** are enabled; in **Admin console** → **Security** → **API controls** → **Domain-wide delegation**, confirm the client ID is authorized for the scopes.

• **How to implement if missing:** Enable the APIs, create the OAuth client / service account, and authorize the scopes:

- `https://www.googleapis.com/auth/admin.directory.group.readonly`
- `https://www.googleapis.com/auth/admin.reports.audit.readonly`

- `https://www.googleapis.com/auth/drive.readonly` (read/assessment)
- `https://www.googleapis.com/auth/drive` and

`https://www.googleapis.com/auth/admin.directory.group` **only** for `--apply` provisioning/membership changes. **No keys are committed or hardcoded** — the tools use OAuth/ADC or a securely-referenced credential (see §3 and each script's header).

Global Requirements — Google Workspace & Gemini Solutions

These requirements apply to **every** solution in the **Google** category. They are the common foundation each Google Workspace / Gemini solution assumes is already in place (or stands up as part of its own Requirements section). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Google solution).*** *The **Google Admin console** (admin.google.com), **Google Cloud / Cloud Identity**, and the **Microsoft / Entra** sides are authored at exact, current click-by-click detail from the vendors' public documentation. **Gemini Enterprise** capabilities that are in preview or rolling out are **cited or flagged "verify in your tenant"** — never invented. **Third-party migration tools** (e.g. for mail/Drive/Chat data movement) and **third-party enterprise apps** (ServiceNow, SAP, Databricks, etc.) are integrated at the pattern/architectural level; their internal console steps are deferred to the vendor's own docs.*

1. Google Workspace / Cloud Identity tenant

- **Description:** A provisioned Google Workspace (or Cloud Identity) tenant with a **super-admin** account for configuration, and the appropriate Workspace edition/licensing for the capability in scope (e.g. Enterprise Plus for Vault/CAA/DLP, Gemini/AI add-on where required).
- **Why required:** All configuration, policy, and API work is performed against this tenant.
- **How to verify:** Sign in to **admin.google.com** as a super-admin; confirm edition and license counts under **Billing / Subscriptions**.
- **How to implement if missing:** Provision the tenant and licenses through Google or an authorized reseller before starting.

2. Source Microsoft 365 / Entra environment (for migration & coexistence)

- **Description:** For migration/coexistence/identity solutions, administrative access to the source **Microsoft 365** tenant and **Microsoft Entra ID** (Global Administrator or the least-privilege roles the solution names).
- **Why required:** Migration, directory sync, SSO federation, and coexistence read from and change the Microsoft side.
- **How to verify:** Confirm access to the M365 admin center and the Entra admin center with the required role.

• **How to implement if missing:** Obtain the role from the M365/Entra tenant owner.

3. DNS control for the routed domains

• **Description:** Ability to create/modify **DNS records** (MX, SPF, DKIM, DMARC, TXT, CNAME) for the domains being migrated, coexisting, or verified.

• **Why required:** Domain verification, mail routing/coexistence, and authentication all depend on DNS changes.

• **How to verify:** Confirm access to the authoritative DNS zone for each domain.

• **How to implement if missing:** Coordinate with whoever controls DNS; stage changes under change control (mail-flow changes are high-impact).

4. Identity & provisioning source of truth

• **Description:** A defined **identity source of truth** (on-prem AD, Entra ID, or an HR/IGA system) and the sync mechanism (e.g. **Google Cloud Directory Sync (GCDS)** or SCIM-based provisioning).

• **Why required:** Consistent users/groups across ecosystems underpin SSO, licensing, and access.

• **How to verify:** Confirm which directory is authoritative and how objects flow into Google.

• **How to implement if missing:** Define the source of truth and provisioning model before configuring SSO or migrating.

5. A pilot scope (OU / group) and change control

• **Description:** A **pilot organizational unit or group** to validate on before fleet-wide rollout, and a **change-control** process for production changes (especially mail flow, DNS, identity, and DLP).

• **Why required:** Every solution follows an **Assess** → **Configure** → **Pilot** → **Validate** → **Expand** model; the pilot proves the design and change control protects production.

• **How to verify:** Confirm a named pilot OU/group exists and a change window/approval path is available.

• **How to implement if missing:** Create a pilot OU/group and agree the change-control process with the owners before making production changes.

6. Security, compliance & governance stakeholders

• **Description:** Engagement with the **security (CISO), legal/eDiscovery, and data-governance** stakeholders whose policies the configuration must satisfy (DLP, retention, Vault/Purview, and any regulatory regime such as ITAR/DFARS/Assured Controls where applicable).

• **Why required:** Data governance, eDiscovery, DLP, and regulated-workload settings must align to enterprise policy and legal requirements, not just technical defaults.

• **How to verify:** Confirm the applicable policies and named stakeholders/approvers.

• **How to implement if missing:** Identify the owners and obtain the policy/compliance requirements before configuring governance controls.

*The deployment model across every Google solution is the same: **Assess** → **Configure** → **Pilot** → **Validate** → **Expand**, with explicit pass/fail gates and a documented rollback for production changes.*

3. Implementation Guide

This guide stands up the Drive & Shared Drives architecture following the house model — **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand** — with every artifact **named** on a consistent convention and reused in later steps, testing, and the scripts. Production sharing changes are **pilot-first**, **gated**, and **rollback-ready**.

Naming conventions used throughout (agree once, reuse exactly):

• Shared Drive: `Shared Drive – <Domain> – <Team/Function> – <Purpose>` (e.g. `Shared Drive – Finance – AP Records`)

• Membership group: `grp-<function>-<purpose>@<domain>` (e.g. `grp-finance-ap@corp.example`)

• Manager (owner) group per Drive: `grp-<function>-drive-owners@<domain>`

• Target audience: `Audience – <Scope> – <Purpose>` (e.g. `Audience – Internal – All Staff`, `Audience – Partner – AcmeLegal`)

• Trust rule: `Trust Rule – <Direction> – <Partner> – <Mode>` (e.g. `Trust Rule – Outbound – AcmeLegal – Allow`)

• Sharing setting profile (per OU): `Sharing Profile – <OU> – <Posture>` (e.g. `Sharing Profile – Finance – Restricted`)

• DLP rule: `DLP – <Detector> – <Action>` (e.g. `DLP – NationalID – Block-External`)

• Pilot scope: `Pilot OU – Drive – Finance`

• Reviews: `Access Review – <Drive> – <Quarter>`, `Orphaned-Owner Sweep – <Scope> – <Date>`

3.1 Assess — inventory the current Drive exposure (read-only)

Establish the Stage-0 baseline before changing anything.

1. Run the sharing-exposure assessment against the pilot scope:

```
python drive_sharing_exposure_assessment.py --domain corp.example \
    --ou "/Finance" --json > baseline-finance.json
```

It reports (read-only): files shared **externally**, files with **"Anyone with the link"**, **orphaned-owner** files (owner is a suspended/deleted user), and content held in **My Drive** that should be in a Shared Drive.

1. Record the baseline counts. These are the numbers the Validation step must improve on.

2. Review current Admin-console sharing state: **Admin console → Apps → Google Workspace → Drive and

Docs → Sharing settings** — note the current external-sharing, link-sharing, and Shared Drive creation settings per OU (so the rollback baseline is documented).

> ***Gate G0 (Assess complete):*** *a baseline JSON exists for the pilot scope and the current Admin-console sharing settings are documented. Do not proceed without a recorded rollback baseline.*

3.2 Design — agree the taxonomy, roles, sharing policy, DLP alignment, governance

Produce the signed-off design (Requirement 2.5). Decide and document:

1. **Taxonomy & naming** — the top-level domains (Corporate Functions / Business Units / Projects /

Cross-Org Collaboration) and the `Shared Drive – <Domain> – <Team> – <Purpose>` standard.

1. **Role model** — the default role per member group and the named **Manager group per Drive**

(`grp-<function>-drive-owners@…`). Least-privilege default: most groups **Contributor** or **Viewer**; **Manager** only for the owner group.

1. **External-sharing policy** — the posture per OU (`Sharing Profile – <OU> – Restricted` by default),

the allow-listed partner domains, and which **target audiences** and **trust rules** implement them.

1. **DLP alignment** — which classification levels (2.3) map to which `DLP – <Detector> – <Action>`

rules on external sharing.

1. **Lifecycle governance** — the review cadence (`Access Review – <Drive> – <Quarter>`), the

orphaned-owner and stale-Drive sweep schedule, and the provisioning standard.

Validate the naming/role model with the config helper (no tenant change):

```
python drive_governance_config_helper.py --catalog drive-catalog.csv \
    --new-drive "Finance – AP Records" --domain Finance --owner-group grp-finance-drive-owners@corp.exampl
    --member-group grp-finance-ap@corp.example --member-role contributor
```

> ***Gate G1 (Design signed off):*** *the taxonomy, naming, role model, external-sharing policy, DLP mapping, and governance cadence are approved by the Drive service owner and GR-6 stakeholders.*

3.3 Configure — apply sharing settings, audiences, trust rules, DLP (pilot OU first)

Apply configuration to the **pilot OU** (`Pilot OU – Drive – Finance`) only.

1. **Sharing settings (per OU)** — **Admin console → Apps → Google Workspace → Drive and Docs →

Sharing settings**, scoped to the pilot OU. Apply `Sharing Profile – Finance – Restricted`:

- **Sharing outside <domain>:** set to **OFF** or **allow-listed domains only** per the design.

- **"When sharing outside … users will see a warning": ON**.
- **Access checker / link sharing default:** set link-sharing default to **restricted** ("Only added people"), not "Anyone with the link".
- **Shared Drive creation:** restrict who can create Shared Drives (default to admins/service owners so provisioning stays governed), and set defaults for members outside the org, download/copy, and non-member access per the design.

1. **Target audiences** (edition-gated) — **Admin console** → **Directory** → **Target audiences**. Create `Audience – Internal – All Staff` (and any partner audiences), so the sharing dialog's default suggested audience is the governed one, not "Anyone with the link."

1. **Trust rules** (edition-gated) — **Admin console → Apps → Google Workspace → Drive and Docs → Trust rules**. Create `Trust Rule – Outbound – <Partner> – Allow` for each allow-listed partner domain and a default-restrict rule; scope to the pilot OU first. *Verify the exact page layout in your tenant — this surface is edition-gated and evolving.*

1. **DLP for Drive** (edition-gated) — **Admin console** → **Security** → **Data protection** → **Manage rules**. Author `DLP – <Detector> – Block-External` / `DLP – <Detector> – Warn-External` rules mapping the 2.3 detectors to **block** or **warn** actions on **external** sharing; scope to the pilot OU.

1. **Provision the pilot Shared Drives** to the naming model — either in **Admin console → Apps → Google Workspace → Drive and Docs → Manage Shared Drives**, or with the provisioner in dry-run then `--apply`:

```
python shared_drive_provisioner.py --catalog drive-catalog.csv --dry-run
python shared_drive_provisioner.py --catalog drive-catalog.csv --apply   # after review
```

The provisioner creates each `Shared Drive – …` and adds the **member group** at the designed role and the **owner group** as **Manager** — never individual users.

3.4 Pilot — run the design against the pilot scope

1. Relocate the pilot team's business content from My Drive into the provisioned Shared Drives (owner transfer / move), so no business content remains individually owned.

1. Have the pilot team collaborate normally for the agreed pilot window (internal shares, one allow-listed partner share, one blocked-by-DLP attempt).

1. Monitor for broken collaborations and DLP false-positives; adjust rules within the pilot only.

> ***Gate G2 (Pilot pass/fail):*** *PASS requires — no business content left in pilot users' My Drive; external sharing limited to the allow-listed audience(s); a genuine sensitive-content external share is* ***blocked/warned*** *by DLP; the pilot team can still do its legitimate work.* ***FAIL*** *on any broken legitimate workflow or any un-scoped external leak →* ***rollback*** *(§3.6) and revise the design.*

3.5 Validate & Expand

1. Re-run the assessment and the validation report against the pilot scope:

```
python drive_sharing_exposure_assessment.py --domain corp.example --ou "/Finance" --json > post-finance
```

```
python drive_governance_report.py --catalog drive-catalog.csv --exposure post-finance.json --out financ
```

Confirm exposure counts dropped to policy (no orphaned owners, no un-scoped external shares).

1. Run the policy/health check as the go/no-go gate:

```
python external_sharing_policy_validator.py --domain corp.example --ou "/Finance" --catalog drive-catal
```

Exit **0** = pilot conforms to policy; non-zero = a violation remains.

1. **Expand** domain by domain, repeating Configure → Pilot → Validate per OU, keeping the provisioning

standard and the review cadence as steady-state governance (`Access Review – <Drive> – <Quarter>`, scheduled `Orphaned-Owner Sweep – <Scope> – <Date>`).

3.6 Rollback (documented, per production sharing change)

If a Gate fails or a production change breaks collaboration:

1. **Sharing settings:** in **Drive and Docs** → **Sharing settings** for the affected OU, restore the

documented G0 baseline values (this is why §3.1 recorded them).

1. **Trust rules / target audiences:** disable or delete the `Trust Rule – …` / `Audience – …`

created for the change (audiences/rules are additive; removing them reverts behavior).

1. **DLP rules:** set the offending `DLP – <Detector> – …` rule action to **audit only** (non-blocking)

or deactivate it, so no legitimate work is blocked while the rule is revised.

1. **Provisioned Shared Drives:** membership changes are reversible via the provisioner's recorded

before-state; a wrongly-created Shared Drive is emptied and hidden/deleted through **Manage Shared Drives** by a Manager. Rollback restores the pre-change posture; re-enter Design with the lesson recorded.

5. Testing & Validation

Each test below has an **expected pass/fail** result. Run them against the **pilot scope** first (`Pilot OU – Drive – Finance`), then per OU as you Expand. Tests map to the gates in the Implementation Guide. The Python tools referenced are all **read-only** for validation.

Test 1 — Sharing exposure reduced to policy (Gate G2 / Validate)

• **Procedure:** Re-run `python drive_sharing_exposure_assessment.py --domain corp.example --ou "/Finance" --json`

and compare to the G0 baseline (`baseline-finance.json`).

• **Expected PASS:** External-shared and "Anyone with the link" counts drop to the design's allowed

set (only shares to the approved `Audience – …`); orphaned-owner count is **0**; business content in My Drive count is **0** for pilot users.

• **FAIL:** Any un-scoped external / link share, or any orphaned-owner or My-Drive business file

remains → remediate or **rollback** (§3.6).

Test 2 — External-sharing policy conformance (go/no-go gate)

- **Procedure:** Run `python external_sharing_policy_validator.py --domain corp.example --ou "/Finance" --catalog drive-catalog.csv`.
- **Expected PASS:** Exit code **0** — configured sharing (OU sharing settings, target audiences, trust rules) matches the `Sharing Profile – Finance – Restricted` design; no partner domain outside the allow-list is reachable.
- **FAIL:** Non-zero exit listing the specific violation (e.g. external sharing still ON where design says allow-listed only).

Test 3 — Link-sharing default is restricted

- **Procedure:** As a pilot user, create a new Doc in a pilot Shared Drive and open **Share** — observe the default access. Also confirm via the assessment's link-sharing count.
- **Expected PASS:** Default is **"Only added people"** (restricted), not "Anyone with the link"; sharing outside the domain shows the outside-domain **warning**.
- **FAIL:** New files default to "Anyone with the link" or external sharing proceeds with no warning.

Test 4 — Target audience is the default suggestion

- **Procedure:** In a pilot Shared Drive file, open **Share** → **"Add people and groups"** and check the suggested audience.
- **Expected PASS:** `Audience – Internal – All Staff` (the governed audience) is offered as the default, replacing the generic "Anyone with the link."
- **FAIL:** The generic public-link option is the default (target audience not applied to the OU).

(Edition-gated — if target audiences are unavailable on your edition, this test is N/A; rely on Tests 2/3 and the OU sharing settings.)

Test 5 — DLP blocks/warns on sensitive external sharing

- **Procedure:** As a pilot user, place a **synthetic** sensitive value that matches a `DLP – <Detector> – …` rule (e.g. a test national-ID pattern) into a Doc in a pilot Shared Drive and attempt to share it **externally**.
- **Expected PASS:** The `DLP – <Detector> – Block-External` rule **blocks** the external share (or **warns**, per the rule action); the event appears in **Security** → **Data protection** / the security investigation tool.
- **FAIL:** The external share of matching sensitive content succeeds silently. *(Use only synthetic test data — never real regulated content.)*

Test 6 — Membership is group-based, roles are least-privilege

- **Procedure:** In **Manage Shared Drives**, open a pilot Shared Drive's membership; or run the governance report and inspect the membership section.
- **Expected PASS:** Members are **Google Groups** (`grp-…`), not individual users; the **Manager** role is held only by the owner group `grp-<function>-drive-owners@…`; other groups are Contributor/Viewer per the role model.
- **FAIL:** Individual users are direct members, or a non-owner group holds **Manager**.

Test 7 — No orphaned ownership

- **Procedure:** Run the assessment (or the governance report) and inspect the orphaned-owner section (files owned by suspended/deleted users).
- **Expected PASS:** Orphaned-owner count is **0** for the scope — business content lives in organization-owned Shared Drives, so no file is stranded on a departed user.
- **FAIL:** Any file still owned by a suspended/deleted user → transfer to a Shared Drive.

Test 8 — Governance reporting is in place

- **Procedure:** Run `python drive_governance_report.py --catalog drive-catalog.csv --exposure post-finance.json --out finance-governance.html` and open the report.
- **Expected PASS:** The report lists each `Shared Drive – …` with its owner group, member groups + roles, external-share and orphaned-owner counts, and flags stale/empty Drives and any Drive lacking a Manager group — i.e. the artifacts a quarterly `Access Review – <Drive> – <Quarter>` needs.
- **FAIL:** The report cannot enumerate owners/members or omits the exposure/lifecycle sections.

Test 9 — Rollback restores the baseline

- **Procedure:** In a change window, execute the §3.6 rollback for one setting (e.g. revert `Sharing Profile – Finance – Restricted` to the G0 value) and re-run Test 1/2.
- **Expected PASS:** The pre-change posture is restored and validation reflects the baseline — proving the change is reversible before production expansion.
- **FAIL:** The setting cannot be cleanly reverted → do not expand until rollback is proven.

6. Troubleshooting

Common failure modes when standing up and governing the Drive & Shared Drives architecture, with resolutions. Ordered roughly by where they surface in Assess → Configure → Pilot → Validate.

API & automation

`403 insufficientPermissions` / `accessNotConfigured` *from a Python tool*

• **Cause:** The Admin SDK or Drive API is not enabled in the Cloud project, or the OAuth client / delegated service account is not authorized for the scope the tool needs.

• **Resolution:** Enable **Admin SDK API** and **Google Drive API** in the project. In **Admin console → Security → API controls → Domain-wide delegation**, authorize the client ID for the exact scopes in Requirement 2.6 (read-only for assessment/validation; add the write scopes** only **for** `--apply`**). Confirm the impersonated identity holds the** Drive and Docs** admin privilege (2.1).

`403 domainAdminAccess` *when listing Shared Drive permissions in the governance report*

• **Cause:** `useDomainAdminAccess=true` requires the caller to be an administrator with the Drive privilege; a non-admin identity cannot enumerate all Shared Drives' permissions.

• **Resolution:** Run the tool as (or impersonating) the 2.1 admin identity. If you only need Drives you are a member of, remove admin-access and accept the reduced scope.

`403 userRateLimitExceeded` / `429` */ throttling on large scans*

• **Cause:** Drive API per-user/per-project quota exceeded during a wide `files.list` sweep.

• **Resolution:** Lower `--max`, run against a single `--ou` at a time, and re-run during off-peak windows. Add exponential-backoff retries if you extend the tools; request a quota increase in the Cloud project for genuinely large estates. The assessment is resumable — take the baseline in batches.

Assessment returns very few files or misses external shares

• **Cause:** The impersonated identity cannot see content it is not an admin over, or `allDrives` traversal was not used.

• **Resolution:** Confirm the tool is run with the admin identity and that `includeItemsFromAllDrives`/`supportsAllDrives` are set (they are in the shipped tools). For a full estate view, use a delegated service account impersonating a Drive admin.

Configuration & sharing

External sharing still succeeds after tightening the OU sharing setting

• **Cause:** Sharing settings are inherited by OU — the user is in a **different OU** than the one you changed, or a **trust rule / target audience** is still permitting the share, or the change has not propagated.

• **Resolution:** Verify the user's OU in **Directory** → **Users**; apply `Sharing Profile – <OU> – Restricted to the correct OU. Check **Trust rules** for an over-permissive Trust Rule – …. Setting propagation can take time – re-run external_sharing_policy_validator.py` after propagation; it is the authoritative gate.

Target audiences / trust rules pages are missing

- **Cause:** These controls are **edition-gated** (Enterprise/Education tiers).
- **Resolution:** Confirm the edition in **Billing** → **Subscriptions** (Requirement 2.4). On lower editions, fall back to OU-level sharing settings + manual review driven by `drive_sharing_exposure_assessment.py`; flag the gap to the licensing owner.

DLP rule blocks legitimate work (false positives)

- **Cause:** A `DLP – <Detector> – Block-External` rule's detector is too broad, or was shipped straight to **block** without an audit/warn tuning phase.
- **Resolution:** Set the rule action to **audit only** to observe matches, tighten the detector (add confidence thresholds / context, narrow the word-list/regex), move to **warn**, then **block**. This is the documented DLP rollback (§3.6). Never ship a blocking rule cold.

DLP does not fire on a synthetic external share (Test 5 fails)

- **Cause:** The rule is scoped to the wrong OU, the trigger doesn't include Drive external sharing, or the detector doesn't match the synthetic value.
- **Resolution:** Confirm the rule's **scope** covers the pilot OU and its **trigger** is Drive/external sharing; verify the synthetic value matches the detector pattern; check **Security** → **Data protection** logs / the security investigation tool for a near-miss.

Ownership, membership & provisioning

Orphaned-owner files remain after relocating content (Test 7 fails)

- **Cause:** Files were **copied** into a Shared Drive rather than **moved/owner-transferred**, so the originals still exist owned by the departed user.
- **Resolution:** Move (transfer ownership) the originals into the Shared Drive, or use Drive's transfer-ownership flow; then trash the personal-drive copies. Re-run the assessment to confirm the orphaned-owner count is 0.

Provisioner refuses a member (`must be a GROUP email`)

- **Cause:** The catalog lists an individual **user** as a member; the design mandates group-based membership.
- **Resolution:** Create/choose the appropriate Google Group (2.2), add the user to that group, and put the **group** in the catalog. This is intentional — it keeps access auditable and directory-driven.

Provisioner creates a duplicate Shared Drive

- **Cause:** `drives().create` is not idempotent across sessions — re-running `--apply` on a row whose Drive already exists makes a second Drive of the same name.

- **Resolution:** Use `drive_governance_config_helper.py` (which refuses duplicate names in the catalog) and run the provisioner's **dry-run** first; if a duplicate was created, empty and delete it through **Manage Shared Drives** (rollback §3.6). Track created drive IDs in the catalog.

"Anyone with the link" still appears in the validator after cleanup

- **Cause:** Existing files carry an `anyone` permission from before the policy change — settings govern **new** shares, not retroactively strip old ones.
- **Resolution:** Use the assessment output to target the offending files and remove the `anyone` permission (an `--apply` remediation, or manual for a small set); re-run `external_sharing_policy_validator.py` until it exits 0.

Gates & rollback

A pilot gate (G2) fails

- **Cause:** A legitimate workflow broke or an un-scoped external leak remains.
- **Resolution:** Execute the documented **rollback** (§3.6) — restore the recorded G0 sharing settings, disable the offending trust rule/audience, set the DLP rule to audit-only — then re-enter Design with the lesson recorded. Do **not** expand past a failing gate.

7. Best Practices

Durable practices for keeping the Drive & Shared Drives estate governed as it grows.

Architecture & taxonomy

- **Business content belongs in Shared Drives, not My Drive.** Make organization-ownership the default for anything a team relies on; reserve My Drive for personal, transient work. This single rule eliminates the orphaned-ownership problem at the source.
- **Express hierarchy as Drives + naming, not deep folders.** Shared Drives are flat by design. Keep the top-level domain set small and governed; encode structure in the `Shared Drive – <Domain> – <Team> – <Purpose>` name, and reuse that exact name in groups, reports, and scripts.
- **One Manager (owner) group per Drive.** Every Shared Drive has a named `grp-<function>-drive-owners@…` as **Manager** — never a lone individual. Ownership is a role a group holds, so it survives departures.

Membership & least privilege

- **Add groups, never users.** Members of a Shared Drive should be Google Groups synced from the directory source of truth; manage people by changing group membership, so access is auditable in one place. The provisioner and the config helper both refuse individual-user membership.

• **Default to the lowest useful role.** Most groups are **Contributor** or **Viewer**; **Content

manager **where a team genuinely curates structure;** Manager** only for the owner group. Grant up, never down.

• **Review membership on a cadence.** Run `Access Review – <Drive> – <Quarter>` from the governance

report; remove groups that no longer need access.

Sharing & the trust boundary

• **Restrictive by default, opened deliberately.** Set OU sharing to internal-only or allow-listed,

curtail "Anyone with the link," and require outside-domain warnings. Open external sharing only via a named **target audience** / **trust rule** for a specific partner — recorded in the catalog's allow-list.

• **Prefer target audiences over public links.** A governed audience as the default share suggestion

quietly steers users away from public links without blocking legitimate collaboration.

• **Let classification drive DLP, not the other way around.** Author `DLP – <Detector> – <Action>`

rules from the approved data-classification scheme; start rules in **audit**, move to **warn**, then **block** once false-positives are tuned — never ship a blocking rule cold into production.

Governance & lifecycle

• **Provision through the standard, not ad hoc.** Restrict Shared Drive creation to the service owner /

automation, and create every Drive through the catalog + provisioner so naming and roles stay consistent.

• **Sweep for orphaned owners and stale Drives regularly.** Schedule `Orphaned-Owner Sweep – <Scope> –

<Date>` and act on empty/stale-Drive flags from the governance report before they accumulate.

• **Keep the three surfaces coherent.** The catalog (design), the tenant (live config), and the

reports (evidence) must agree; re-run the validator after every change so drift is caught early.

Safety & operations

• **Pilot every production sharing change, and keep the rollback baseline.** Record the pre-change OU

sharing settings before touching them; sharing tightening can break active work, so gate it and be ready to revert.

• **Run the tools read-only first.** Every write tool defaults to dry-run/`--apply`-gated; review the

planned actions before applying, and keep the before-state lines for rollback.

• **No secrets in code or repo.** The tools authenticate via OAuth/ADC or a delegated service account

resolved at runtime; never commit keys, exported credentials, or tokens.

8. Deliverables Summary

This solution delivers a complete, self-guided package for designing and governing the steady-state Google Drive & Shared Drives architecture — the written guides plus five Python automation tools.

Documentation

- **Solution Overview** — the Drive model: My Drive vs Shared Drives, taxonomy & naming, membership/

role model, external + link-sharing policy, target audiences & trust rules, DLP alignment, and governance/lifecycle, with the reference design and deployment model.

- **Requirements Guide** — the solution-specific prerequisites (Drive & Docs admin privilege, Google

Groups as membership source of truth, data-classification/DLP inputs, edition gating, agreed taxonomy, and API access), each with how to verify and how to implement if missing — on top of the shared Google global requirements.

- **Implementation Guide** — exact ordered steps following Assess → Design → Configure → Pilot →

Validate → Expand, every artifact named, with pass/fail gates (G0–G2) and a documented rollback.

- **Testing & Validation** — nine tests, each with expected pass/fail, mapped to the gates.
- **Troubleshooting** — common failure modes (API scope/permission errors, throttling, external-share

leaks, DLP false-positives, orphaned ownership, provisioning duplicates) and their resolutions.

- **Best Practices** — durable practices for keeping the estate governed as it grows.
- **Executive Summary** — the outcome, approach, and why the change is low-risk.

Python tools (Google Workspace Admin SDK / Drive API)

All five are **safe-by-default** (read-only or `--dry-run` unless `--apply`), authenticate via OAuth/ADC or a delegated service account (no credentials or keys in code), and print clear results.

1. `drive_sharing_exposure_assessment.py` *(read-only)* — the Stage-0 baseline: finds files shared

externally, "Anyone with the link" exposures, orphaned-owner files (owned by suspended/deleted users), and business content still in My Drive. Exits 0 (assessment, not a gate).

1. `shared_drive_provisioner.py` *(dry-run default; `--apply` to write)* — creates the Shared

Drives from the governance catalog to the naming model and adds **group** members at their designed roles (owner group as Manager); refuses individual-user membership; prints before-state for rollback.

1. `external_sharing_policy_validator.py` *(read-only gate)* — the go/no-go gate: samples live

permissions and flags external shares to non-allow-listed domains and public links. Exit 0 = conforms; non-zero = a violation remains.

1. `drive_governance_report.py` *(read-only; writes a local report only)* — enumerates each Shared

Drive with its owner/member groups + roles, exposure counts (merged from the assessment), and lifecycle flags (no-Manager-group, individual-member, empty/stale Drive) for the quarterly access review.

1. `drive_governance_config_helper.py` *(local-only; dry-run default)* — validates and appends

correctly-shaped rows to the governance catalog against the taxonomy/naming/role model (group-based membership, least-privilege, named owner group); no Google API calls, no tenant change.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

drive_governance_config_helper.py

drive_governance_report.py

drive_sharing_exposure_assessment.py

external_sharing_policy_validator.py

shared_drive_provisioner.py